

Codex 엔터프라이즈 롤아웃 설계

Linton Labs 청구 플랫폼 파일럿 → 다팀 확산 · 1페이지 롤아웃 제안서 · 작성일 2026-08-25 · 이해관계자: 마라(AI 구현 책임자) · 프리야(스태프 엔지니어) · 조나스(SRE 책임자) · 레오(제품 책임자)

1. 표면 전략 (Surface Strategy)

[결정 1] 청구 플랫폼 팀(프리야 소속)의 기본 서프یس는 **CLI + 워크트리 필수**. 동시 다수 엔지니어 작업과 불안전 테스트 커버리지 때문에 각 작업을 격리된 워크트리에서 실행해 병합 충돌·회귀를 방지한다. 비-청구 신규 팀은 IDE 확장으로 먼저 온보딩 후 CLI로 전환.

클라우드(Codex Cloud) 실행은 **PR 생성 전 검증 단계에서만 허용**하며, 고객 청구 데이터에 접근하는 프로덕션 자격증명이 필요한 작업에는 **금지**. 로컬/CLI 워크트리에서 완료 후 결과만 클라우드로 업로드해 리뷰 생성.

Windows 사용자: 기본값은 **WSL**(리눅스 툴체인 설치, 샌드박스 예측 가능). 네이티브 Windows 샌드박스가 필요한 경우 **unelevated 모드**가 기본이며, 관리자 권한이 IT 정책으로 차단된 PC는 WSL로 자동 대체.

2. 모델 전략 (Model Strategy)

[결정 2] 대부분 작업의 기본 모델은 최신 **GA(정식 출시) Codex 모델**(현재 표준 티어)로 고정하고, API 키 기반 워크플로우(CI 혹은, 배치 스크립트)에도 동일한 최신 사용 가능 모델을 사용해 응답 특성을 일치시킨다.

추론 노력(reasoning effort)은 **청구 계산 로직·마이그레이션 등 고위험 변경**에서만 상향하며, 단순 리팩터링·문서화는 기본 노력 유지.

Spark(초저지연)는 IDE 자동완성형 짧은 루프에만 적용하고, 청구 저장소의 다단계/장시간 작업에는 **적용 불가**. Spark 사용 시 범위를 단일 파일·단일 함수로 축소하고 반드시 사람이 명시적으로 diff를 검증한 뒤 커밋한다(검증 요건 강화).

3. 컨텍스트 연속성 플레이북 (Context Continuity)

[결정 3] 체크포인트는 ① **PR 단위 작업 시작 시**, ② **30분 경과 시**, ③ **테스트 3회 연속 실패 시** 트리거되어 결정 사항과 diff 상태를 스냅샷으로 저장한다.

압축(compaction)은 스냅샷 직후, 대화가 컨텍스트 한도의 70%에 도달할 때 수행하며 결정 사항·미해결 이슈·다음 단계는 압축 요약에 필수 보존한다.

[복구 패턴 1] 실패한 시도 롤백: 동일 접근이 2회 실패하면 마지막 체크포인트로 되돌리고 다른 전략(예: 더 작은 단위 분할)으로 재시도한다.

[복구 패턴 2] 드리프트 감지 & 스레드 재시작: 원래 요구사항과의 편차가 감지되면 현재 스레드를 종료하고 최근 체크포인트 + AGENTS.md 요구사항을 다시 로드하여 새 스레드로 재시작한다. 서프یس 전환(CLI↔클라우드)이 필요한 경우도 동일한 체크포인트 재로딩 절차를 따른다.

4. 거버넌스 번들 (Governance Bundle)

[가이드라인: 규칙(.rules)] **[결정 4]** 저장소 루트에 **.rules** 파일로 안전 명령(테스트/린트/빌드 실행)은 허용, 위험 명령(강제 푸시, DB 마이그레이션 직접 실행, 프로덕션 배포 CLI)은 차단 목록으로 명시한다. config.toml은 저장소별 **.codex/config.toml**에 저장하고 팀 전체 기본값을 리포지토리 템플릿으로 배포.

AGENTS.md에는 검증 명령(예: `npm test`, `make lint`), 리뷰 가이드라인, "완료(Done)" 정의(테스트 통과 + 리뷰어 1인 승인)를 명시해 신규 인원도 별도 설명 없이 착수 가능하게 한다.

고부가가치 워크플로우는 "보안 PR 검토", "CI 수정 루프", "릴리스 노트" 3종을 표준 프롬프트로 템플릿화하여 재사용한다.

5. 클라우드 환경 정책 (Cloud Environment Policy)

[가이드라인: 샌드박스 기본값] **[결정 5]** 클라우드 실행 환경의 샌드박스 기본값은 **격리(네트워크 격리 + 파일시스템 스냅샷)**이며, 설정 스크립트는 의존성 설치 결과를 캐싱해 반복 실행 시간을 단축한다.

[가이드라인: 비밀 정보(Secrets)] 청구 API 키·DB 자격증명 등 **비밀 정보는 시크릿 매니저에만 저장**하고 절대 환경 변수나 코드에 하드코딩하지 않는다. 환경 변수는 비민감 설정값(리전, 로그 레벨 등)에만 사용.

[가이드라인: 인터넷 접근] 에이전트의 인터넷 접근은 **기본 비활성화**이며, 패키지 레지스트리 등 필요한 도메인만 화이트리스트로 예외 허용한다(요청 시 조나스 승인 필요).

6. 통합 (Integrations)

GitHub 코드 리뷰는 청구 저장소에서 **수동 @codex review 호출만 허용**(자동 리뷰는 노이즈·오타 우려로 비활성화). 안정화 후 비핵심 저장소부터 자동 리뷰 순차 적용.

Slack/Linear에서는 이슈 트리아지·초안 답변 위임은 가능하나, 고객 대상 커뮤니케이션 발송과 이슈 상태를 "완료"로 변경하는 작업은 사람이 직접 승인 후 처리(절대 위임 불가).

7. 관리 및 모니터링 계획 (Admin & Monitoring)

로컬 활성화는 전 엔지니어 기본 허용, 클라우드 활성화는 **RBAC "cloud-codex" 그룹** 소속자만 가능(청구 저장소 접근권과 별도 관리).

추적 신호: 분석 로그(사용량·모델·서프یس 분포)와 규정 준수 로그(승인 이력, 비밀 정보 접근 시도)를 분리 보관하며 규정 준수 로그는 90일 보존.

지원 런북: 사용자 이슈 발생 시 ① 승인 대기 여부 ② 샌드박스/환경 설정 ③ RBAC 접근 권한 순으로 확인. Windows 지원 점검은 관리자 권한 여부 → 활성 샌드박스 모드(unelevated/elevated) → 로그인 경로/권한 순으로 확인한다.

본 문서는 config.toml · AGENTS.md · .rules 등 실제 저장소에 배치되는 아티팩트와 명시적 승인/에스컬레이션 절차만으로 구현 가능하며, 별도의 비공개("비밀 지식")를 요구하지 않는다.